note/08_セキュリティ · 2026-10-17 動的鍵の運用仕様改訂版 · 非正典・本番未実装・未検証

動的鍵の更新・負荷制御・障害時運用の仕様

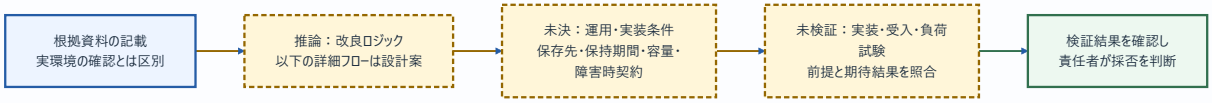
本書は、動的鍵の設計思想と仕様に従うシステムの運用契約を説明します。更新する対象と頻度、必要な状態保存、更新競合、再試行、処理枠、障害時の停止・再開を具体化します。認証・認可の必須条件は主文書と共通です。

〈推論〉本設計の位置付け



以下は、確認できた資料を根拠に、既存APIへ追加する改良部分を組み立てた設計案です。実サービスの構成・運用条件との適合は未確認です。根拠資料に記載された現況を、実環境で確認済みの事実として扱いません。

- **推論**：資料から導いた処理順序・分岐・改良ロジックです。設計上の提案であり、実装済み・安全性検証済みという意味ではありません。
- **未決**：実装前に責任者が決める条件です。保存先、保持期間、処理容量、障害時の扱い、外部処理との整合方法などは、対象サービスごとに決定します。
- **未検証**：実ブラウザでの描画・印刷、本番APIへの組込み、受入試験、負荷・障害試験は確認が残っています。



色は処理上の役割を示します。青は通常処理、紫は検証・判定、緑は完了・許可、黄土色の破線枠は待機・再試行・推論・未決、赤は拒否・停止・異常です。色だけで確定性を判断せず、ノードと分岐の文字を確認してください。緑のノードも設計案に含まれ、実サービスでの成功を意味しません。

接続線は原則として接続先の役割と同じ色です。差戻し・再試行は黄土色で示します。破線矢印の意味は元の図のラベルに従い、すべてを未決とは読み替えません。

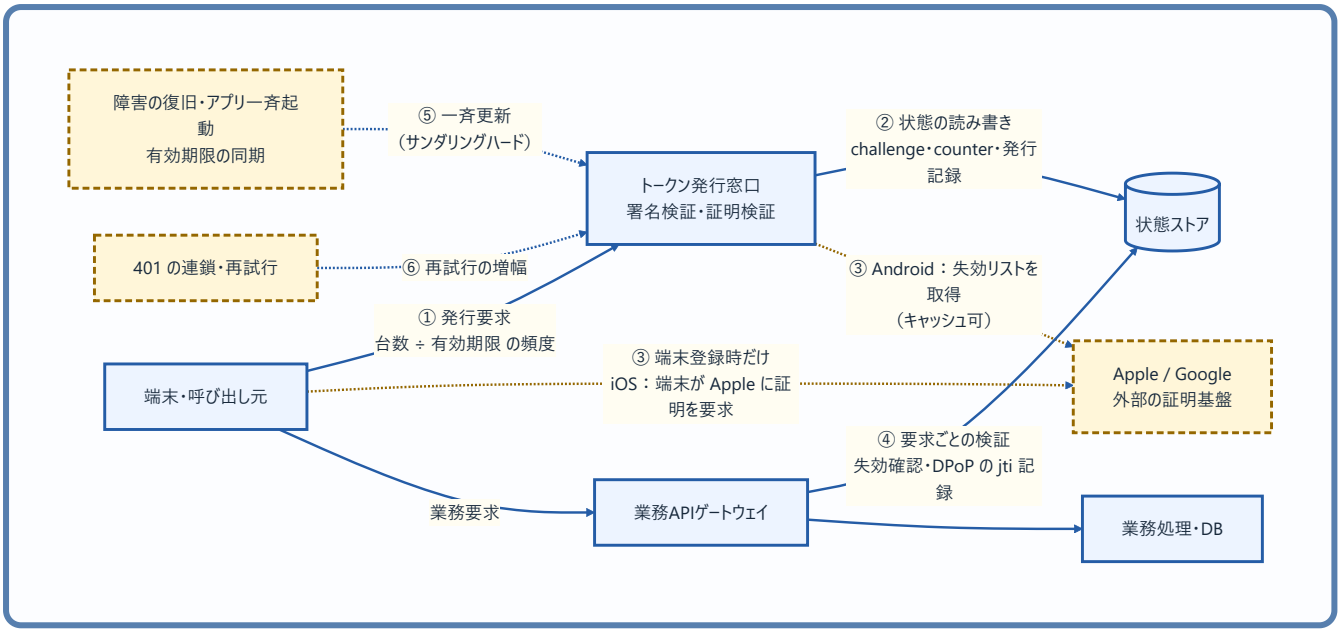
1. 運用上の設計思想

動的鍵の導入では、登録時の端末・本人確認、期限ごとの資格発行、各要求のproof検証に、それぞれ負荷が生じます。これらの発生頻度を分けて設計します。端末の秘密鍵は要求ごとに作り直さず、アクセストークンは期限まで利用し、DPoP proofだけを各HTTP送信で新しくします。

処理枠と時間の使い方で集中を抑えます。混雑を理由に署名、鍵拘束、失効、proofの再利用防止、対象認可を省略しません。静的キー廃止で減る不正通信も含めた総負荷の増減は、実測で判定します。

処理	起きるタイミング	主に使う資源	本案での制御
端末鍵の生成と証明	初回登録・承認された鍵更新	端末の保護領域、OS別証明、登録正本	登録専用枠。日常の業務呼出しと分離
アクセストークン発行	初回認証・有効期限前の更新	grant検証、発行署名、失効・更新・操作正本	発行枠、ジッター、Single-Flight
業務APIの要求検証	要求・再送・状態照会ごと	JWT・DPoPの署名、鍵拘束、再利用・失効状態	入口制限、公開鍵キャッシュ、署名確認後の状態記録
業務確定と結果返却	新規操作・既存操作の照会	業務DB、操作一意性、DTO、返却枠	新規実行と照会を区別。実件数・実バイトを送信前に確定

図1　負荷はどこで生まれるか



図の①⑤⑥は発行窓口、②④は状態ストアへ集中します。iOSとAndroidの証明・外部照会はOS別契約で扱います。App Attestのcounter、DPoPのjti、業務operation_idを、同じ種類の再利用防止情報として共用しません。

2. 資格の有効期限と更新予約

access TTLはリスク、失効確認の仕組み、実容量、利用者の操作継続時間を根拠に決めます。短命化は盗用可能な時間を制限しますが、期限内の不正をすべて防ぐものではありません。Refresh Tokenを無期限・無拘束のBearerとして残せば、更新側に長期の危険が残ります。

端末はexpires_inを受信した時点の単調時計を基準に、通信時間の余裕とジッターを含む更新予定を作ります。休止・復帰で予定がずれた場合は資格状態を確認し直します。利用許可はサーバー時計と資格・失効の検証で決め、端末の時計変更で期限を延ばせないようにします。

制御項目	本案の仕様
期限前更新	設定した範囲で端末ごとに時刻をずらす。平常時から同時刻へ集中させない
Single-Flight	同じセッション・更新資格に対する端末内の同時更新を1本へ合流
多端末	端末間の同時更新はサーバーの一意受付・世代検証で扱う

制御項目	本案の仕様
自動更新の回数	元の業務要求で401を受けた場合の自動更新は1回まで。新要求として制御状態を初期化しない
proofの生成	更新、業務再送、結果照会の各送信で、新しいjtiとproofを作る
必須のtoken_type	DPoPを要求するプロファイルでBearerへ暗黙に降格しない

DPoPにおけるpublic clientのRefresh Token鍵拘束は RFC 9449 §5、再利用対策とローテーションの方針は RFC 9700 §4.14 を照合します。ローテーションを使う場合の旧値消費・新値確定・応答消失は、認証基盤と合わせた実装契約が必要です。

3. 発行量と状態保存量の計算例

以下は実測値でも推奨TTLでもありません。アクティブ端末を100万台、各端末が資格を継続使用し、更新周期が独立していると仮定します。平均発行率は台数を平均更新周期で割った値です。先行更新を期限の15〜60秒前へ一様に分散すると、平均の先行時間は37.5秒になります。

access TTL	期限ちょうどの平均発行率	先行更新ありの平均発行率	先行更新による倍率
300秒	1,000,000 ÷ 300 ≒ 3,333件/秒	1,000,000 ÷ 262.5 ≒ 3,810件/秒	8/7 ≒ 1.143
900秒	1,000,000 ÷ 900 ≒ 1,111件/秒	1,000,000 ÷ 862.5 ≒ 1,159件/秒	24/23 ≒ 1.043
3,600秒	1,000,000 ÷ 3,600 ≒ 278件/秒	1,000,000 ÷ 3,562.5 ≒ 281件/秒	96/95 ≒ 1.011

100万台が復旧後60秒で均等に更新すると平均約16,667件/秒となり、300秒TTL・先行更新なしの平均の5倍です。偏りがあればピークはさらに高くなります。平均値をそのまま受付枠にしません。

DPoPの再利用記録数は、記録対象の要求率と保持時間に依存します。例として、契約から算出した保持時間が60秒、保護API要求が20,000件/秒なら、約120万件を保持します。1件あたりのバイト数、インデックス、複製、削除

負荷はこの件数に含めておらず、別途測定します。

4. 再利用防止・操作記録の保持と整合

保存対象	スコープ	消してよい条件	障害時の動作
proofのjti	検証領域・登録鍵・jti	当該proofが全受入ノードで受理不能になり、安全余裕も過ぎた後	一意受入を確認できない保護要求は停止
登録challenge・本人承認	主体・登録操作・目的・鍵	期限・単回使用と監査保持の契約による	不明な承認や古い候補を有効化しない
操作記録とdigest	tenant・主体・操作種別・operation_id	再送・照会・外部突合の契約と監査保持を満たした後	記録喪失を「未実行」とみなさない
失効と更新世代	セッション・鍵・資格・更新family等	残る資格への影響と保持契約を満たした後	失効不明を有効とみなさない

本案はnonceの有無にかかわらずiatの受理窓を維持します。過去側の許容時間をW_past、未来側をW_future、ノード間時刻差・反映遅延等の保守余裕をMとすると、初回受入からの固定保持を使う場合の下限候補は W_past + W_future + M です。値と計算条件を設定契約に残します。受理窓だけを60秒と呼び、未来側許容を無視して60秒後に消す実装は採用しません。DPoP再利用防止 RFC 9449 §11.1

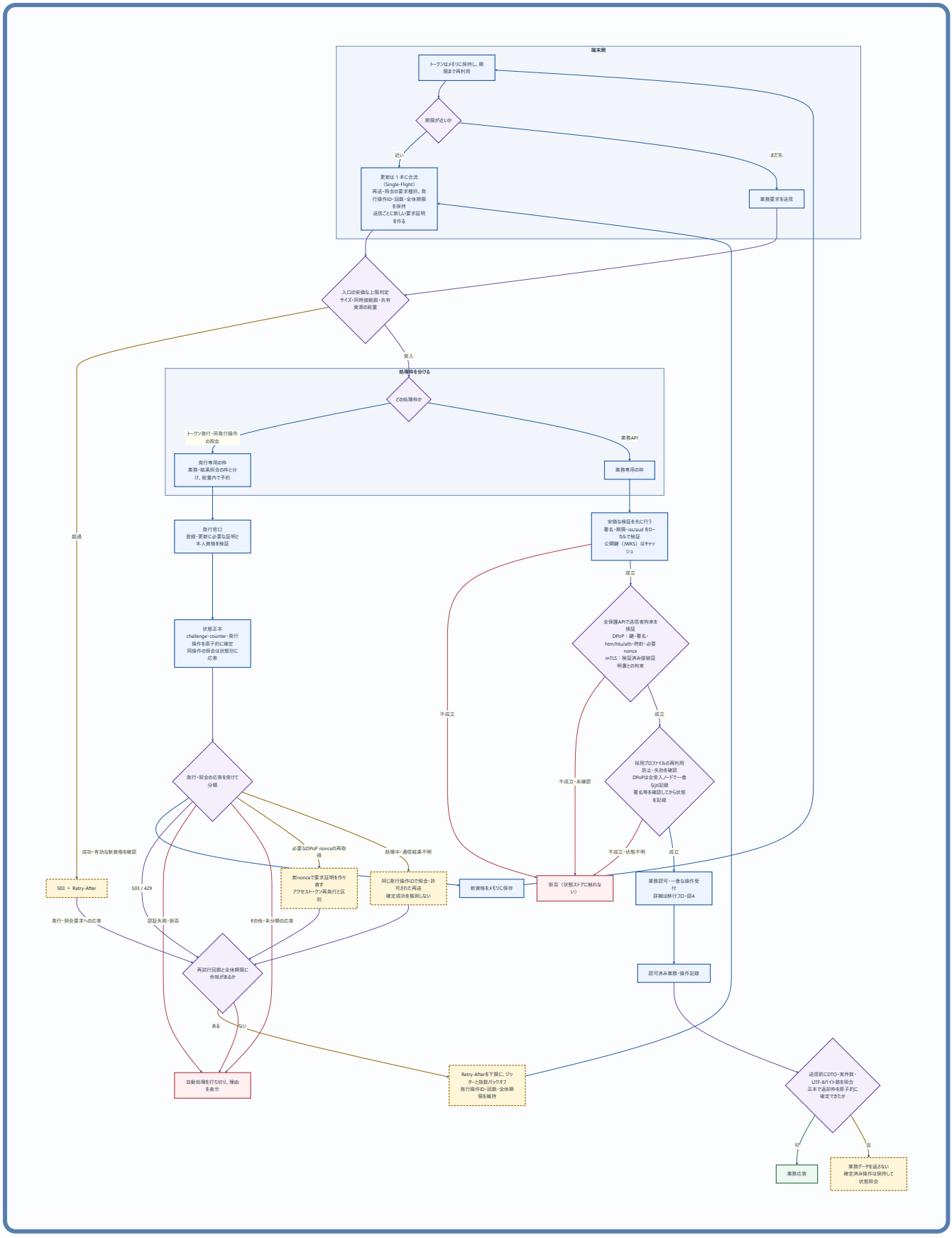
ストアを鍵等で分割しても、同じスコープのproofは必ず同じ一意判定へ到達させます。分断時に各ノードが独立して成功を返す方式では、単回受入を成立させません。正本と任意キャッシュを区別し、復旧時には巻き戻り・未反映・失効世代も照合します。

operation_idの保持はproofの短い保持時間とは別です。契約終了後の古い操作ID再提示も、新規実行として無条件に受理しないよう、利用可能な期間と終了後の応答を定めます。

5. 入口制御・処理枠・共有資源

入口ではサイズ、接続、同時実行、待ち行列、deadlineを安価に確認し、許容量を超えた要求を高コストの検証へ進めません。未認証ヘッダーの主体を、正規利用者の優先枠の根拠にしません。資格検証後に、主体・tenantごとの制限を適用します。

図2　負荷を抑えた要求経路



処理枠	役割	確保する理由
公開案内	公開専用情報と停止理由の案内	保護API停止時にも案内を提供する

処理枠	役割	確保する理由
登録・資格発行	登録証明、更新、同発行操作の照会	発行集中を業務全体へ波及させにくくする
業務	認可済みの読取・更新	業務の資源消費を制御する
結果照会	確定済み・処理中・結果不明の確認	応答消失を新規実行へ変えずに回復する
制御・監査	失効、観測、縮退、監査の永続化	混雑中も停止判断と記録を続ける

CPU、DB接続、状態ストア、回線ごとに、枠の合計と予約分が実容量を超えないようにします。同じ単位で能力100に対して発行80・業務40を許可すると合計120です。専用枠という名称だけでは共有資源の枯渇を防げません。

公開鍵は設定済みの発行者から取得してキャッシュします。未知kidや鍵更新失敗で検証鍵を確認できない要求は拒否・保留し、取得の連打を合流・制限します。署名を確かめる前にjtiストアへ書き込ませず、入力長も制限します。任意URLの鍵取得や未知鍵の許可へ切り替えません。RFC 8725

6. 再試行と応答の分類

端末は応答を受けてから、成功、認証失敗、nonce要求、混雑、処理中、結果不明を分類します。503・429を受けなかったことだけで成功とは判定しません。元業務のoperation_id、更新操作ID、要求種別、回数、全体期限、更新済みフラグを保持します。

応答・状態	端末が行う処理	サーバー側の契約
発行成功	token_type・必要な項目・有効条件を確認して保存	未確定の候補資格を応答しない
401・期限切れ	元業務で未実施なら更新を1回だけ行う	期限切れと別の認証失敗を区別できるエラー契約
DPoP nonce要求	対応する発行元・用途のnonceで新proofを作る	資格再発行とは別に扱い、回数・期限を制限

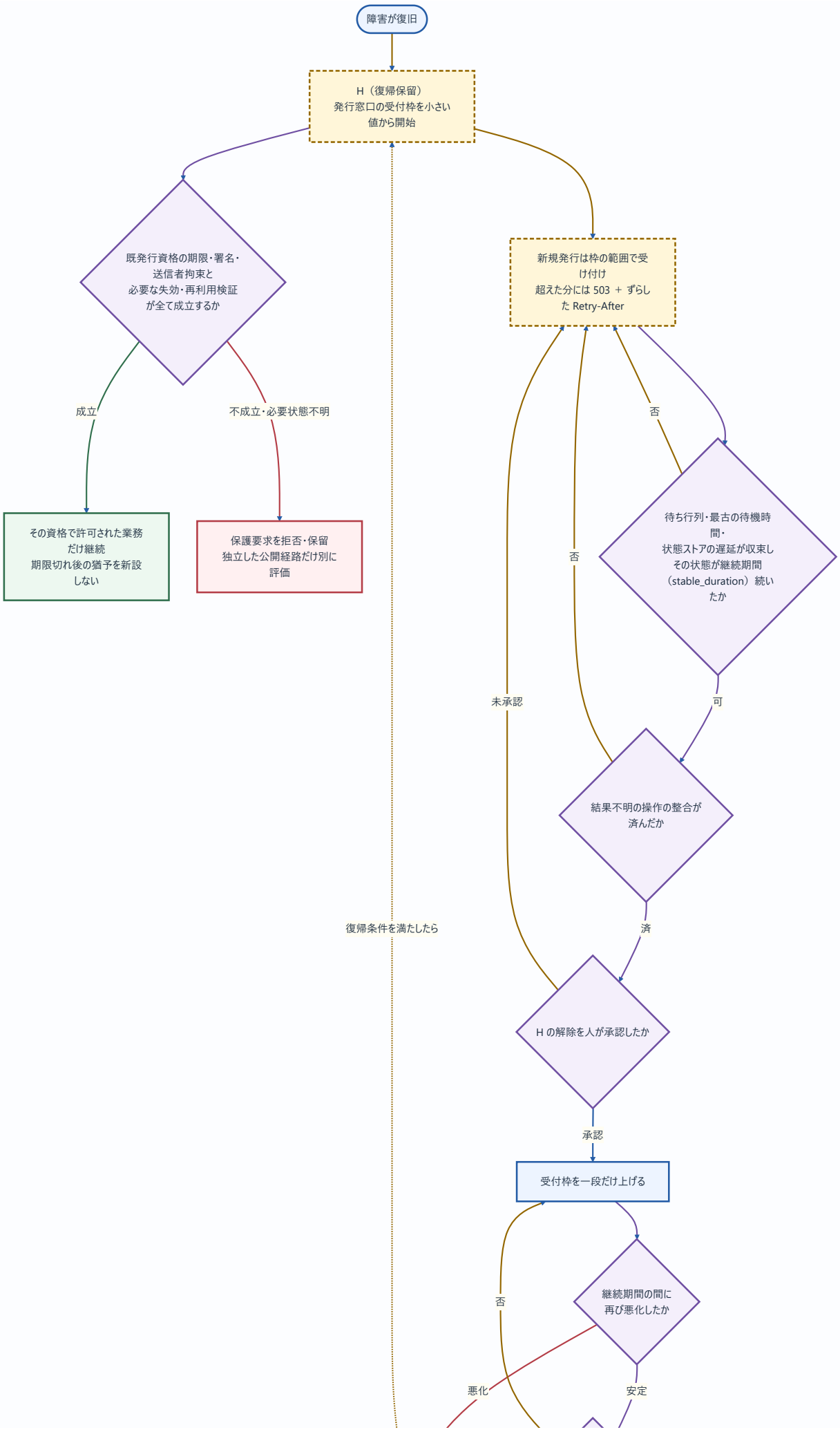
応答・状態	端末が行う処理	サーバー側の契約
403・認可拒否	自動更新で権限を得ようとせず停止	データや操作の存在を不用意に漏らさない
429・入口での503	Retry-After、ジッター、指数バックオフ。上限超過で停止	未受理と表示できるのは業務副作用を起こす前に拒否した場合
202等・PENDING	同じ操作IDで有限の照会	照会可能な主体へ、許可した状態情報だけ返す
通信断・UNKNOWN	同じ操作IDで照会・突合	成功・未実行を推定せず、新IDの重複実行を防止
409・内容不一致	元記録を確認し、自動再実行を止める	同IDのdigest不一致で元記録を上書きしない
その他・未分類	安全側に停止し、利用者へ状態を案内	未分類の応答を成功にしない

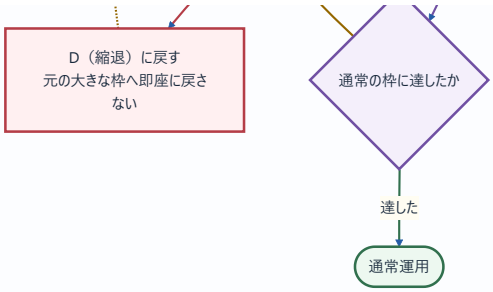
Retry-Afterが全体期限を超える場合は、期限を延ばして待ち続けません。混雑応答と通信断では、業務が確定済みかどうかの知識が異なります。HTTPステータスだけに依存せず、契約した操作状態で判断します。資格発行の応答消失も、同一発行操作の照会・再受取契約へ従います。

7. 障害からの段階再開

再開条件は、待ち行列長、最古の待機時間、状態ストア遅延、欠測、結果不明操作の整合、設定した継続時間を合わせて判断します。CPUの瞬間値だけでは再開しません。

図3　一斉更新が起きたときの段階的な再開


障害が復旧
H（復帰保留）
発行窓口の受付枠を小さい値から開始
既発行資格の期限・署名・送信者拘束と必要な失効・再利用検証が全て成立するか
成立
不成立・必要状態不明
その資格で許可された業務だけ継続
期限切れ後の猶予を新設しない
保護要求を拒否・保留
独立した公開経路だけ別に評価
新規発行は枠の範囲で受け付け
超えた分には 503 ＋ ずらした Retry-After
否
待ち行列・最古の待機時間・状態ストアの遅延が収束しその状態が継続期間（stable_duration）続いたか
否
可
未承認
結果不明の操作の整合が済んだか
済
復帰条件を満たしたら
H の解除を人が承認したか
承認
受付枠を一段だけ上げる
継続期間の間に再び悪化したか
否
悪化
安定



D（縮退）からH（復帰保留）へ移り、stable_durationの継続成立、結果不明操作の整合、必要な人の運用承認を確認して、resume_stepだけ受付枠を増やします。再悪化時はDへ戻します。N/M/D/Hは資源運用の区分であり、鍵登録状態や正典の境界状態とは別です。

既発行資格を継続できるのは、期限、署名、送信者拘束、必要な失効・再利用確認、業務認可がすべて成立する範囲だけです。期限切れの猶予や、停止中の正本検証を省く例外は追加しません。

8. 返却量と観測・設定の仕様

DTOを構築した後、実件数とUTF-8本文バイト数を送信前に確認します。バイト数を確定する表現、圧縮前後のどちらを数えるか、HTTPヘッダーの扱い、一覧・export・streamingの上限は経路台帳で固定します。streamingは、総量の上限を保証する専用契約を確定するまで通常の返却経路へ混在させません。

受付時の見積りや予約だけで最終検査を代替しません。返却枠の不足や正本不明で送信を止めても、確定済みの更新・決済は保持し、操作IDで結果照会できる状態を残します。

分類	必須の記録・設定
資格	access TTL、更新予約、Refresh Token期限・失効・世代、許可署名方式
proof	過去・未来の受理窓、nonce用途・期限、保持余裕、最大長、正本の一意性
再試行	最大回数、全体deadline、バックオフ、Retry-Afterの扱い、更新済みフラグ
入口・共有資源	max_inflight、max_queue、経路別deadline、各枠と共有総量・予約枠

分類	必須の記録・設定
縮退・再開	queue_warn、queue_stop、queue_resume、normal_limit、degraded_limit、resume_step、stable_duration
応答	DTO、件数、UTF-8バイト、期間累積、tenant・主体の枠、照会契約
観測	経路・端末群ごとの失敗理由、発行率、証明失敗、正本遅延、待機時間、重複検出、結果不明、復旧受付

設定には単位、取得元、欠測時動作、版、変更権限、根拠を持たせます。未設定値をゼロや無制限へ変換しません。ログには操作IDと理由コードを残し、アクセストークン、Refresh Token、秘密鍵、proof全文は出力しません。監査不能時の保護操作の扱いも、台帳で事前に決めます。

9. 実装・受入試験との接続

実装対象	合格条件	現状
更新と合流	同時要求・休止復帰・応答消失でも、資格更新と副作用を重複させない	実サービス未検証
proof正本	同じproofを複数ノードへ送って一回だけ受理し、将来iatの境界まで保持	実サービス未検証
入口・総量	発行集中・状態ストア遅延でも共有総量と予約枠を守る	実サービス未検証
再試行	401、nonce、429、503、通信断、未分類で別の動作となり、回数・期限を初期化しない	実サービス未検証
再開	継続条件・整合・承認なしに枠を増やさず、再悪化でDへ戻る	実サービス未検証
結果と返却枠	確定済み業務を再実行せず、実量超過時に業務データを送らない	実サービス未検証

本書の計算例と文書間照合は、容量・可用性・防御効果の試験結果ではありません。採用時は主文書の受付条件と合わせ、実際の端末、認証基盤、正本、Gateway、業務APIで試験します。

参照資料と版

資料	参照範囲・位置付け
A 標準仕様書	原則2・Phase 4。危険な近道は精査を踏まえて不採用
B 移行計画書	再試行・障害の先行案。検証省略は不採用
C 統合設計案	§5〜§7、N/M/D/H。正典の境界状態とは別
2026-10-16 精査 F01〜F12	元資料の精査時点の判定
2026-10-16 具体的提言	§5〜§8、AT01〜AT20。本番実装未検証
移行フロー	設計思想・仕様改訂版の認証・操作受付・実装接続
2026-10-17 再精査 N01〜N10	ローカル監査資料。修正前のハッシュと指摘を保持
N01〜N10 修正・再検証記録	ローカル監査資料。承認した文書修正と未検証範囲を記録
RFC 9449	DPoP検証・nonce・再利用検出。規格と配備固有の方針を分離
RFC 8705	証明書拘束とTLS終端

前版の「再精査P1〜P14」の原報告・採否記録は今回特定できていません。N番号・F番号へ読み替えず、版の判定を分けます。ローカル監査資料は配布同梱を保証しないため、公開時の参照先確認は別途必要です。

この改訂は、負荷の一般説明を、更新周期・状態保持・再試行・共有総量・段階再開・実返却量の運用仕様へ組み直したものです。以前の説明と監査記録は履歴として保持し、仕様の提案と実測・実装結果を分けます。